



DAS Policy

Access Controls

No:
2100-11

Effective:
April 29, 2025

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy addresses **Access Control** requirements to ensure that Ohio Department of Administrative Services (**DAS-Managed System Assets**) are properly protected against unauthorized access while still meeting the access requirements for all authorized **Users**. The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

The scope of this policy includes all User accounts on any DAS-Managed System Assets. This policy also applies to DAS **Data Owners** and **Service Owners**.

III. Policy

To adequately protect DAS-Managed System Assets, Access Control requirements need to be addressed within network, operating system, application and **Information, Mobile Computing, and Teleworking** environments. The appropriate controls also need to be in place for User access management. The Access Controls for these environments need to be selected not only based upon security requirements, but also business and legal requirements. The following policy sections outline requirements for each of these critical Access Control components.

- A. **Business, Legal & Security Requirements for Access Control:** In consideration of business, legal, and security requirements, the Data Owner shall drive the **Authorization** process and access to **Information Technology (IT) Resources** and **Information Assets**. Access Control requirements shall be reviewed at least annually and the occurrence of each review shall be documented:

1. Access shall be commensurate with the security requirements of the DAS-Managed System Asset. Access Controls shall comply with all relevant federal and state laws, executive orders, directives, policies, regulations, standards, and guidance. For example, the controls implemented for protected health Information shall be consistent with the requirements of the Health Insurance Portability and Accountability Act (HIPAA).
 2. **Identification** and **Authentication** controls shall be consistent with the security requirements of the DAS-Managed System Asset. The controls shall comply with all applicable federal and state laws, executive orders, directives, policies, regulations, standards, and guidance. For more detailed Identification and Authentication requirements, refer to DAS Policy 2100-10, "Identification and Authentication."
- B. **User Access Management:** The objective of User access management is to ensure authorized Users, and processes acting on behalf of Users, are able to access DAS-Managed System Assets, while unauthorized Users are prevented from access to the same. Each DAS-Managed System Asset shall have documented system specific procedures and controls that cover all phases in the life cycle of User access.
1. Access to DAS-Managed System Assets shall follow formal procedures for User registration.
 - a) Specific account types shall be defined (e.g., individual, group/shared, service, guest/anonymous, emergency, and temporary. Authorized Users shall be assigned group and role membership, and account access Authorizations (e.g., privileges) for each account.
 - b) Accounts shall not be created, activated or deactivated without obtaining the necessary level(s) of authorized approval. This process shall include a documented access request.
 - c) **Account Administrators** shall be notified when:
 - (i) Users are transferred or terminated; Individual Information system usage or
 - (ii) Need-to-know requirements change; or
 - (iii) Accounts, including shared/group, emergency, and temporary, are no longer required.
 - d) When individuals transfer to DAS from another agency, all previous agency-specific role access to DAS enterprise systems (e.g., Ohio Administrative Knowledge System, Office365, Release and Permit, network file shares, SharePoint, etc.) shall be removed if not already done through the agency off-boarding process.
 - e) The use of group/shared, service, guest/anonymous, emergency, and temporary accounts shall be permitted only if the use is explicitly authorized and monitored.

- (i) Group identifiers shall be assigned to an owner, who is the primary point of contact for the identifier. Procedures shall be developed to manage and document ownership changes.
 - (ii) The use of group/shared and guest/anonymous accounts shall not be authorized to access **Confidential Data**.
 - (iii) When group/shared accounts are permitted, a process shall be established for changing passwords when individuals are removed from the group. In addition, a process shall be established for the individual accountability of members authorized to use the group/shared accounts.
 - 2. In an effort to retain User history and auditability of DAS-managed Information systems, User accounts shall not be deleted.
 - a) **Organizational User** accounts may be archived after 400 days of inactivity.
 - b) **Non-organizational User** accounts may be archived after 800 days of inactivity.
 - 3. Access Control rules shall incorporate the principle of **Least Privilege**, which grants the lowest level of access, rights, privileges, and security permissions needed for the performance of authorized tasks.
 - a) Acceptable Access Control implementation shall include the allocation of User privileges on a need-to-use, per system, per application basis.
 - b) Access Controls shall support business and legal requirements, including job function and separation of duties.
 - c) **Privileged Users** shall be assigned two separate accounts. One account shall be used to perform standard or base level functions (e.g., access to email or Internet) and the other shall be used solely to perform administrator or higher access level functions.
 - 4. User access levels shall be reviewed by the Data Owner (or their designee) at least annually, or more frequently as indicated by the results of the Information system **Risk Assessment** and **Data Classification Label** requirements. The occurrence of each review shall be documented.
- C. **Network Access Control:** Access to internal and external networked systems shall be provided in a controlled manner and shall be protected through a combination of security controls including **Segmentation**, deployment of **Firewalls** and other security appliances and Authentication mechanisms as appropriate (e.g., site-to-site virtual private networks). The security controls shall help to prevent and detect unauthorized access, while providing secure access for authorized Users and systems.
- 1. Whenever possible, connections from specific locations and equipment shall be authenticated using automatic equipment Identification.
 - 2. The need for remote access functionality shall be validated prior to enabling any **Remote Diagnostic** or configuration capabilities.

3. A segmented approach for separating logical network domains shall be adopted.
- D. **Operating System Access Control:** Access to operating systems shall be restricted to authorized Users. Security controls shall be employed to properly authenticate Users, provide appropriate access by role (e.g., administrator), log activities and generate notifications of security events.
1. Secure login procedures that minimize the opportunity for unauthorized access shall be adopted (e.g., access restricted to local logins).
 2. Access and permissions associated with ***Utility Programs***, including programs that are capable of overriding system and application controls, shall be strictly controlled (e.g., documented, vetted for security vulnerabilities/malicious code, deleted when no longer needed, etc.) and limited to only authorized Users.
 3. Inactive sessions shall be locked or terminated after a defined period of inactivity. Typically, ***Session Locks*** shall be implemented at the operating system or application level and session terminations shall be executed at the network or application level. At a minimum, an Information system shall be configured to:
 - a) Prevent further access to the system by initiating a Session Lock after a maximum of 30 minutes of inactivity or upon receiving a request from a User;
 - b) Conceal Information that was previously visible on the display with a publicly viewable image;
 - c) Retain the Session Lock until the User re-establishes access using pre-defined Identification and Authentication procedures; and
 - d) Initiate a ***Screen Lock*** after a maximum of 15 minutes of inactivity.
 4. Connection time shall be limited based upon a defined period of inactivity that requires the User to log out (e.g., at the end of the work day).
- E. **Application and Information Access Control:** Access policies shall be enforced for Information and system functions to protect against unauthorized access and to prevent the compromise of systems from which Information is shared. Access to Information and application systems shall be managed in accordance with state policy.
1. Information systems that require Authentication shall display an approved system use notification message or banner before granting a User access to the system. The notification message or banner shall be modeled after the "DAS OISP-Approved Security Notification for IT Systems," which is available on the [DAS Policies Web page](#). If necessary, the "DAS OISP-Approved Security Notification for IT Systems," may be customized to meet specific requirements. However, as a minimum, the notification message or banner shall include:

- a) Content that is consistent with applicable federal and state laws, executive orders, directives, policies, regulations, standards, and guidance;
 - b) A statement that Users are accessing a State of Ohio Information system;
 - c) A warning that unauthorized use of the Information system is prohibited and subject to administrative action, criminal and civil penalties;
 - d) Notification that Information system usage may be monitored, recorded, and subject to audit; and
 - e) Notice that the use of the Information system indicates consent to monitoring and recording.
 2. The notification message or banner shall remain on the screen until the User takes an explicit action to log on to or further access the Information system.
- F. **Mobile Computing and Teleworking:** Security controls shall be implemented to protect against the unique risks introduced by accessing IT Resources from potentially unprotected environments.
1. Wireless and remote access methods and controls, including ***Wireless Local Area Network (WLAN)*** access, shall use only approved and supported remote access methods and enforce required resource controls.
 - a) It is prohibited to allow offshore access to state computer systems via virtual private networks.
 - b) Users shall sign all applicable Mobile Device Acknowledgement and/or Remote Access User Acknowledgements prior to being given access to Mobile Computing IT Resources.
 2. If Users have approval to engage in Teleworking in accordance with DAS Policy 200-14, “Teleworking,” procedures shall be in place to mitigate and address the added risks associated with Teleworking and remote access to IT Resources. Users shall be required to adhere to state and agency policies, standards, and contracts while accessing IT Resources via a Teleworking environment.
- G. **Exception Requests:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the “Services & Products” category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact Information).

IV. Definitions

- A. Access Control. Process of granting or denying specific requests: 1) for obtaining and using Information and related Information processing services; and 2) to enter specific physical facilities.¹
- B. Account Administrator. For the purposes of this policy, this is an individual who can create, activate or deactivate system accounts as well as assign access privileges or permissions to Users.
- C. Authentication. Verifying the identity of a User, process, or device, often as a prerequisite to allowing access to IT Resources in an Information system.²
- D. Authorization. A grant to a requesting entity (computer, system, person or process) for access to a protected system and its IT Resources. Not all entities will have access to all state Information. Authorization requirements can be implemented using techniques such as Access Control lists, file and resource permissions, and digital certificates.
- E. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- F. DAS-managed System Asset. Information, hardware, software and services required to support state business, and identified during the Risk Assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- G. Data Classification Label. Denotes the level of protection based on the confidentiality and criticality requirements of data in accordance with the agency's Risk Assessment. Data Classification Labels enable policy-based standards for securing and handling data and sharing Information among organizations. The terms, "Data Classification Label" and "classification label," are used interchangeably.³
- H. Data Owner. The Data Owner is responsible for the Identification and classification of Information, in consultation with Legal Counsel, and shall address the assignment of Data Classification Labels, data compilation, data classification coordination, data classification

¹ FIPS 201-2, Personal Identity Verification (PIV) of Federal Employees and Contractors. Federal Information Processing Standards Publication (FIPS) September 2013. <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.201-2.pdf>>.

² "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

³ Stine, Kevin, Rich Kissel, William C. Barker, Jim Fahlsing, Jessica Gulick. "NIST Special Publication 800-60 Revision 1, Volume I: Guide for Mapping Types of Information and Information Systems to Security Categories," U.S. Department of Commerce National Institute of Standards and Technology, August, 2008 <https://csrc.nist.gov/publications/nistpubs/800-60-rev1/SP800-60_Vol1-Rev1.pdf>.

compliance and data access. The role of a Data Owner and his/her associated responsibilities are addressed in detail within Ohio Administrative Policy IT-13, “Data Classification.”

- I. Firewall. A device or program that controls the flow of network traffic between networks or hosts that employ differing security postures.⁴
- J. Identification. An act or process that presents an identifier to a system so that the system can recognize a system entity (e.g., User, process, or device) and distinguish that entity from all others.⁵
- K. Information. Data processed into a form that has meaning and value to the recipient to support an action or decision. “Information” is often used interchangeably with “data” in common usage and in this policy.
- L. Information Assets. Data that is created, processed and used by the business. The Information may be stored in paper copies as well as electronic files (e.g., hard drives, USB flash memory devices, CD's, DVD's, back-up tapes etc.)
- M. Information Technology (IT) Resources. Any Information technology resource, such as computer hardware and software, IT services, telecommunications equipment and services, digital devices such as digital copiers and facsimile machines, supplies and the Internet, made available to employees, contractors, temporary personnel and other agents of the state in the course of conducting state government business in support of agency mission and goals.
- N. Least Privilege. The security objective of granting Users only those accesses they need to perform their official duties.⁶
- O. Mobile Computing. Refers to a variety of mobile devices (e.g., laptop, tablet or smartphone) that allow Users to access data and Information from anywhere and at any time.
- P. Non-organizational User. A User who is not an Organizational User⁷, which for the purposes of this policy includes public Users.
- Q. Organizational User. An Organizational User is anyone who is an employee of the state, or is otherwise authorized to work on behalf of the State, and who has a need to access State of Ohio IT systems and has secured agency Authorization for such access. The organizational identifier will help to distinguish the individual during the Authentication process. Examples of resources that may fall into this category include full-time employees, part-time employees, seasonal employees, temporary contract workers, independent contractors or consultants, volunteers or unpaid interns. The Organizational User identifier category may

⁴ Scarfone, Karen, Paul Hoffman. “NIST Special Publication 800-41 Revision 1, Guidelines on Firewalls and Firewall Policy, Recommendations of the National Institute of Standards and Technology,” U.S. Department of Commerce National Institute of Standards and Technology, September 2009 <<https://csrc.nist.gov/publications/nistpubs/800-41-Rev1/sp800-41-rev1.pdf>>.

⁵ “CNSS Instruction No. 4009, National Information Assurance (IA) Glossary,” Committee on National Security Systems, April 2010 <<https://www.hsdl.org/?abstract&did=7447>>.

⁶ Nieves, Michael, Kelley Dempsey, Victoria Yan Pillitteri, “NIST Special Publication 800-12, Revision 1, An Introduction to Information Security,” U.S. Department of Commerce National Institute of Standards and Technology, June 2017 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>.

⁷ *Ibid.*

also include university and federal government resources.

- R. Privileged User. A User that is authorized (and, therefore, trusted) to perform security-relevant functions that ordinary Users are not authorized to perform.⁸
- S. Remote Diagnostic. Provide the ability to assess the overall integrity and efficiency of a system network from a remote location. The Remote Diagnostic can also identify issues that are inhibiting the efficiency of the equipment, and sometimes even resolve those issues during the running of the diagnostics. The diagnostic process utilizes wired or wireless communication to conduct the remote analysis.
- T. Risk Assessment. The process of identifying, prioritizing, and estimating risks to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the state, resulting from the operation of an Information system.⁹
- U. Screen Lock. An Information system Session Lock mechanism, when activated on a device with a display screen, places a publicly viewable pattern onto the associated display, hiding what was previously visible on the screen. A Screen Lock requires Authentication to access the data. Screen Locks can be activated manually or in response to rules.
- V. Segmentation. Dividing a computer network into sub-networks, each being a network segment or network layer. Network Segmentation boosts performance and improves security.
- W. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
- X. Session Lock. A temporary action taken by an Information system to lock a connection to an application or system in a window or screen after a defined time period of inactivity or upon a request by the User until the User reestablishes access using established Identification and Authentication procedures.
- Y. Teleworking. The ability for an organization's employees and contractors to perform work from locations other than the organization's facilities.¹⁰
- Z. User. An individual or (system) process authorized to access an Information system.¹¹
- AA. Utility Programs. Utility Programs are designed to aid in the management and tuning of operating systems, computer hardware and application software. Utility Programs perform a specific task related to the management of computer functions, resources, or files (e.g., password protection, memory management, virus protection, and file compression).

⁸ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁹ *Ibid.*

¹⁰ Souppaya, Murugiah, Karen Scarfone, "NIST Special Publication 800-46 Revision 2, Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security," U.S. Department of Commerce National Institute of Standards and Technology, July 2016 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-46r2.pdf>>.

¹¹ "FIPS 200, Minimum Security Requirements for Federal Information and Information Systems." U.S. Department of Commerce National Institute of Standards and Technology, March 2006 <<https://csrc.nist.gov/publications/fips/fips200/FIPS-200-final-march.pdf>>.

BB. Wireless Local Area Network (WLAN). A group of wireless networking devices within a limited geographic area, such as an office building, that exchange data through radio communications. The security of each WLAN is heavily dependent on how well each WLAN component—including client devices, APs, and wireless switches—is secured throughout the WLAN lifecycle, from initial WLAN design and deployment through ongoing maintenance and monitoring.¹²

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 200-14, Teleworking	https://ohid.ohio.gov/wps/myportal/gov/myohio/my-agency/das/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
Ohio Revised Code 1347.15, Access rules for confidential personal Information	https://codes.ohio.gov/ohio-revised-code

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology

¹² Souppaya, Murugiah, Karen Scarfone, "NIST Special Publication 800-153, Guidelines for Securing Wireless Local Area Networks (WLANs), Recommendations of the National Institute of Standards and Technology," U.S. Department of Commerce National Institute of Standards and Technology, February 2012. <<https://csrc.nist.gov/publications/nistpubs/800-153/sp800-153.pdf>>.

Ohio Department of Administrative Services
30 East Broad Street, 39th Floor

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
10/10/2017	Original Policy.
8/17/2018	Reviewed policy and moved disabled account and self-service mechanism requirements to the now published DAS IT Standards, DAS-ITS-2100-01-A Password Standard for Organizational Users and DAS-ITS-2100-01-B Password Standard Non-organizational Users.
11/26/2018	Updated the exception request language to align with the current procedure.
06/10/2020	Updated the policy template.
09/14/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data.